nullghost

GUÍA DE INVESTIGACIÓN

Gestión y seguridad de IA con ISO

Qué pide ISO/IEC 42001, qué cubre ISO/IEC 27090, cómo aprenderlas en cuatro semanas y cómo investigar un sistema de IA con evidencia.

ISO/IEC 42001:2023 + ISO/IEC 27090:2026

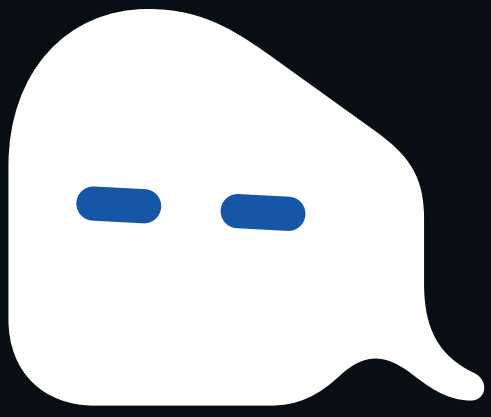
Para equipos pequeños de seguridad y de gobierno de IA. Basada en el alcance público de las normas y en fuentes abiertas; sin certificación ni conformidad demostrada.

UNA RUTA DE TRABAJO

01 Entender las dos normas

02 Aprenderlas con método

03 Investigar con evidencia



Ricardo Martínez · NullGhost

19 OCT 2026 / v0.3 · VERSIÓN DE TRABAJO

11 PÁGINAS

01 / INVESTIGACIÓN

Para qué sirve esta guía

OBJETIVO

Que una persona con base en seguridad entienda qué pide cada norma, aprenda a usarlas en cuatro semanas y pueda investigar un sistema de IA real con evidencia que otro pueda revisar.

Si necesitas…	Ve a
Saber qué es cada norma y cómo se relacionan	02 Las dos normas en una página
Conocer la estructura de ISO/IEC 42001	03 Cláusulas y 04 Anexo A
Conocer las amenazas que cubre ISO/IEC 27090	05 Amenazas y vocabulario abierto
Aprenderlas rápido	06 Camino de cuatro semanas
Investigar un sistema sin afirmar de más	07 Evidencia y 08 Caso de práctica

Cómo está hecha

Se apoya en el alcance público de las normas [1, 2], en descripciones de terceros [3, 4] y en fuentes abiertas sobre ataques a sistemas de IA [5, 6, 7]. No leímos el texto íntegro de ninguna de las dos normas ISO: lo que se dice de ellas es su alcance y su estructura pública, no el contenido de sus requisitos o controles. Cada fuente lleva una etiqueta: [P] leída directamente, [S] secundaria o no reverificada.

El complemento práctico es el Manual de buenas prácticas de IA, con fichas y plantillas para aplicar lo que aquí se explica.

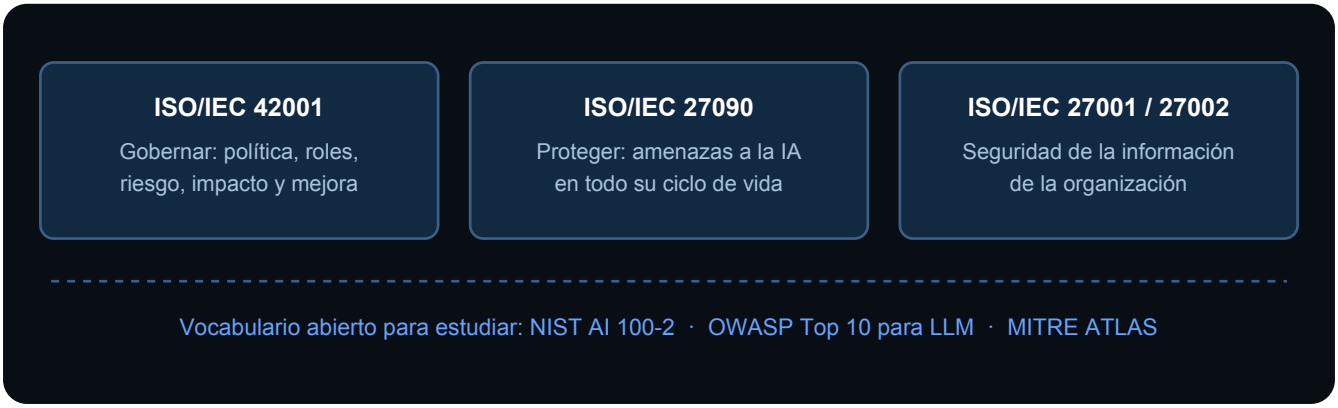
QUÉ NO ES

Una interpretación autorizada de las normas, una lista de cumplimiento ni un sustituto de leerlas. Para certificarse hace falta la edición completa y un proceso con un organismo acreditado.

02 / INVESTIGACIÓN

Las dos normas en una página

ISO/IEC 42001 dice cómo debe gobernar una organización sus sistemas de IA. ISO/IEC 27090 trata de cómo se atacan esos sistemas y qué hacer al respecto. Una cubre la gestión; la otra, las amenazas técnicas.



Aspecto	ISO/IEC 42001:2023	ISO/IEC 27090:2026
Tipo de documento	Requisitos para un sistema de gestión de IA [1].	Guía de orientación sobre amenazas y compromisos de seguridad [2, 3].
Pregunta que responde	¿Quién decide, con qué política y cómo se controla y mejora el uso de IA?	¿Qué amenazas existen en cada fase del ciclo de vida y cómo detectarlas y mitigarlas?
Certificación	Certificable de forma voluntaria por organismos acreditados [1, 4].	Por ser una guía, no define requisitos para certificar (inferencia nuestra, a confirmar).
Con qué se combina	Comparte la estructura de cláusulas de otras normas de sistemas de gestión, como ISO/IEC 27001 [4].	Complementa las prácticas de ISO/IEC 27001 y 27002 con amenazas propias de la IA [3].

En la práctica, 42001 te obliga a evaluar riesgos e impactos de tus sistemas de IA, y 27090 te ayuda a que esa evaluación técnica no se quede corta en amenazas que una evaluación de seguridad clásica no contempla.

03 / INVESTIGACIÓN

ISO/IEC 42001 por dentro: las cláusulas

Las cláusulas 4 a 10 son los requisitos auditables del sistema de gestión. Siguen la estructura común de las normas de sistemas de gestión ISO, por eso quien conoce ISO/IEC 27001 reconoce el esqueleto [4]. El resumen de cada una es nuestro, de alto nivel.

Cláusula	Qué pide, en una línea
4 Contexto	Entender la organización, las partes interesadas y definir el alcance del sistema de gestión de IA.
5 Liderazgo	Compromiso de la dirección, política de IA y roles con responsabilidad asignada.
6 Planificación	Riesgos y oportunidades, evaluación y tratamiento de riesgos de IA, evaluación de impacto del sistema de IA (6.1.4) y objetivos [4].
7 Apoyo	Recursos, competencia, concienciación, comunicación e información documentada.
8 Operación	Planificar y controlar la operación; ejecutar las evaluaciones y los tratamientos.
9 Evaluación del desempeño	Seguimiento y medición, auditoría interna y revisión por la dirección.
10 Mejora	No conformidades, acciones correctivas y mejora continua.

La pieza nueva: la evaluación de impacto

La evaluación de impacto del sistema de IA (6.1.4) mira hacia afuera: qué efectos puede tener el sistema sobre personas, grupos y la sociedad. Es distinta de la evaluación de riesgos para la organización (6.1.2) y se piden las dos [4]. Es lo que más diferencia a 42001 de una norma de seguridad de la información.

04 / INVESTIGACIÓN

ISO/IEC 42001 por dentro: el Anexo A

El Anexo A es un catálogo de referencia: 38 controles agrupados en 9 objetivos, de A.2 a A.10 [4]. La organización revisa todos, aplica los que corresponden y justifica las exclusiones en la Declaración de Aplicabilidad. Los títulos siguientes vienen de catálogos de terceros; los identificadores exactos de cada control deben verificarse en la norma.

Objetivo	De qué trata
A.2 Políticas relacionadas con la IA	La política de IA y su relación con otras políticas.
A.3 Organización interna	Roles y responsabilidades sobre la IA dentro de la organización.
A.4 Recursos para sistemas de IA	Datos, herramientas, cómputo y personas que el sistema necesita.
A.5 Evaluación de impactos	Cómo se evalúan los impactos sobre personas, grupos y sociedad.
A.6 Ciclo de vida del sistema de IA	Gestión responsable del sistema a lo largo de su ciclo de vida, del diseño al retiro.
A.7 Datos para sistemas de IA	Calidad, procedencia y preparación de los datos.
A.8 Información para partes interesadas	Qué se informa a usuarios y afectados.
A.9 Uso de sistemas de IA	Uso responsable conforme a la finalidad prevista.
A.10 Terceros y clientes	Proveedores, clientes y responsabilidades compartidas.

CÓMO USARLO

Para cada sistema de IA, anota qué objetivo del Anexo A cubre cada práctica y deja la referencia exacta pendiente hasta leerla en la norma. Rellenar por parecido de palabras produce una matriz que no resiste una auditoría.

05 / INVESTIGACIÓN

ISO/IEC 27090: amenazas y vocabulario abierto

27090 orienta sobre amenazas y compromisos de seguridad contra sistemas de IA a lo largo de su ciclo de vida: qué consecuencias pueden tener y cómo detectarlas y mitigarlas. Según el ISO27k Forum cubre al menos una docena de escenarios de ataque deliberado, entre ellos el envenenamiento de datos y de modelos, la inversión de modelos y el robo de modelos [3]. No cubre todos los riesgos de la IA.

Mientras consigues la norma, las fuentes abiertas dan el vocabulario técnico. La correspondencia de la tabla es nuestra y aproximada: sirve para estudiar, no como mapeo oficial.

Amenaza	Dónde estudiarla en abierto	Fase del ciclo de vida
Envenenamiento de datos o modelos	NIST AI 100-2, ataques de envenenamiento [5]; OWASP LLM04 [6].	Datos y entrenamiento.
Inversión de modelos y fuga de datos	NIST AI 100-2, ataques de privacidad [5]; OWASP LLM02 [6].	Operación.
Robo o extracción de modelos	NIST AI 100-2, ataques de privacidad [5]; MITRE ATLAS [7].	Operación.
Inyección indirecta de prompts	NIST AI 100-2, sección 3.4 [5]; OWASP LLM01 [6].	Operación con contenido externo.
Agentes con herramientas	NIST AI 100-2, sección 3.5 [5]; OWASP LLM06, agencia excesiva [6].	Operación e integración.
Cadena de suministro	NIST AI 100-2, sección 3.2 [5]; OWASP LLM03 [6].	Desarrollo y despliegue.

MITRE ATLAS agrega casos reales documentados de cada técnica, útiles para entender cómo ocurre un ataque y no solo cómo se llama [7].

06 / INVESTIGACIÓN

Cómo aprenderlas en cuatro semanas

El orden va de lo público a lo de pago y de lo conceptual a lo aplicado. Estimamos entre cuatro y seis horas por semana para una persona con base en seguridad; es una estimación nuestra, no una medición.

1 Semana 1: mapa

Leer el alcance público de 42001 y 27090. Dibujar de memoria el ciclo de vida de un sistema de IA propio con sus activos: datos, modelo, prompts, herramientas y salidas. Prueba: explicar en tres minutos la diferencia entre las dos normas.

2 Semana 2: amenazas

Recorrer NIST AI 100-2, OWASP LLM Top 10 y MITRE ATLAS. Armar una tabla de amenazas por fase y por fuente. Prueba: clasificar un incidente descrito en un párrafo sin mirar la tabla.

3 Semana 3: controles

Leer la norma con una pregunta por amenaza: qué control propone, cuál ya existe en la organización y qué evidencia lo demuestra. Es la única semana que exige el texto de pago.

4 Semana 4: aplicar

Elegir un sistema real y acotado, modelar sus amenazas, marcar controles y brechas y decidir el riesgo residual. Prueba: modelar un sistema nuevo en noventa minutos y contrastarlo con otra persona.

> **RECUPERAR, NO RELEER**
>
> En la revisión de Dunlosky y colaboradores, la práctica de recuperación y la práctica espaciada tuvieron utilidad alta; releer y subrayar, baja [8]. Cada semana termina con una prueba sin apuntes que se repite al día siguiente, al tercero y al séptimo. El esquema de repeticiones es nuestro.

07 / INVESTIGACIÓN

Investigar con evidencia

Saber las normas no basta: una conclusión sobre un sistema de IA solo vale lo que vale su evidencia. Proponemos seis registros enlazados por un identificador de evaluación: alcance, contexto, plan de prueba, observación, verificación y conclusión. El detalle de cada uno está en el manual.

Cuatro estados que no deben mezclarse

1. ### Propuesto
   El plan existe; no se ha ejecutado.

2. ### Observado
   Hay una respuesta o una captura, con su contexto.

3. ### Reproducido
   Un segundo intento bajo condiciones declaradas obtiene el mismo efecto.

4. ### Verificado
   Un revisor comprueba que la evidencia sustenta la afirmación, acotada.

Son una convención de NullGhost, no categorías de ISO. Un resultado negativo se escribe «no observado bajo estas condiciones», nunca «no es vulnerable». Si el instrumento falla o se agota el tiempo, la prueba es inconclusa, no segura.

> **REGLA DE PUBLICACIÓN**
>
> Antes de publicar, otra persona debe poder reconstruir qué se autorizó, qué se hizo y qué cambió. Si solo puede leer una conclusión convincente, el informe no está listo.

08 / INVESTIGACIÓN

Un caso para practicar

Un sistema acotado enseña más que uno amplio. Ejemplo: un asistente de ayuda dentro de una plataforma, como la guía de módulo de KIRUX, con un diseño deliberadamente estrecho: usa solo un modelo local, no tiene herramientas, recibe únicamente el texto fijo del módulo y ningún dato de clientes, la respuesta se valida en el servidor y hay límites de uso por usuario.

Decisión de diseño	Amenaza que acota	Qué falta por probar
Sin herramientas	Agencia excesiva (OWASP LLM06).	Que ninguna ruta del código le dé acciones por otra vía.
Sin datos de clientes	Fuga de información sensible (LLM02).	Que el texto del módulo no contenga nada sensible.
Límites de uso	Consumo sin límites (LLM10).	Que los límites se apliquen por usuario y no por sesión.
Validación en servidor	Salidas no esperadas.	Que la validación rechace respuestas con enlaces o código.

La tabla no demuestra que el asistente sea seguro: muestra qué amenazas reduce el diseño y cuáles quedan abiertas. La más evidente es la inyección de prompts (LLM01) desde la pregunta del usuario, que es justo lo que la semana cuatro debería modelar y probar.

09 / INVESTIGACIÓN

Límites y siguiente versión

Lo que esta guía no hace

1. ### No interpreta las normas

   No leímos su texto íntegro. Lo que se dice de ellas es alcance y estructura pública, con fuentes secundarias marcadas.

2. ### No mide eficacia

   El camino de cuatro semanas y el método de evidencia son propuestas sin validar con otros equipos.

3. ### No certifica

   Una guía, un repositorio público y un PDF no acreditan un sistema de gestión implantado.

Qué cambiaría la versión siguiente

Contrastar todo con las ediciones completas, sustituir las fuentes secundarias por la norma, correr el camino de cuatro semanas con personas reales y publicar los resultados, incluidos los que no funcionen.

> **POLÍTICA DE CAMBIOS**
>
> Cada corrección dice qué afirmación cambia, por qué y con qué fuente. La v0.3 reescribe la v0.2: añade el contenido de las normas y el camino de aprendizaje, y retira un ejemplo que no aportaba al tema.

Referencias

[1] ISO/IEC 42001:2023

[S] Ficha oficial: requisitos para un sistema de gestión de IA; publicada en diciembre de 2023. Texto íntegro no revisado.

https://www.iso.org/standard/42001

[2] ISO/IEC 27090:2026

[S] Ficha oficial. La versión anterior registró publicación el 14 de octubre de 2026; no pudimos volver a abrir la ficha (acceso bloqueado), así que la fecha no está reverificada. Texto íntegro no revisado.

https://www.iso.org/standard/27090

[3] ISO27k Forum (IsecT): ISO/IEC 27090

[S] Descripción del alcance y de las amenazas que cubre (envenenamiento, inversión y robo de modelos, entre otras) y aviso de publicación.

https://www.iso27001security.com/html/27090

[4] Estructura de ISO/IEC 42001 (cláusulas y Anexo A)

[S] Cláusulas 4 a 10, evaluación de impacto (6.1.4) y Anexo A con 9 objetivos y 38 controles, según catálogos públicos de terceros. Verificar contra la norma.

https://riskprofs.com/iso-42001-annex-a-controls-list/

[5] NIST AI 100-2e2025

[P] Vassilev et al., marzo de 2025. Índice leído: 3.4 inyección indirecta de prompts; 3.5 seguridad de agentes. Resto, lectura selectiva.

https://doi.org/10.6028/NIST.AI.100-2e2025

[6] OWASP Top 10 for LLM Applications 2025

[S] OWASP GenAI Security Project, noviembre de 2024. Lista LLM01 a LLM10 según cobertura de terceros.

https://genai.owasp.org

[7] MITRE ATLAS

[S] Base de conocimiento de tácticas y técnicas contra sistemas de IA, modelada sobre ATT&CK, con casos documentados.

https://atlas.mitre.org

[8] Dunlosky et al. (2013)

[S] Improving Students' Learning With Effective Learning Techniques. Psychological Science in the Public Interest. DOI 10.1177/1529100612453266.

https://doi.org/10.1177/1529100612453266

Consulta de fuentes: 19 de octubre de 2026. Elaboración asistida por IA, con revisión técnica humana pendiente. No se redistribuyen las normas.